



SolarWinds Supply-Chain Compromise

Technical Case Study - Anatomy of a Trusted Update Turned Backdoor

When trust became the attack surface.

1. Incident at a glance

The SolarWinds incident demonstrated a strategic reality that now sits at the center of software-supply-chain security: an attacker does not need to compromise every downstream organization individually if they can compromise the mechanism those organizations already trust to deliver software.

ATTACK CLASS

Software supply-chain compromise / cyber espionage

PRIMARY PRODUCT

SolarWinds Orion Platform

BUILD IMPLANT

SUNSPOT

DELIVERED BACKDOOR

SUNBURST / Solorigate

ATTRIBUTED ACTOR

Russian SVR; commonly tracked as APT29 / NOBELIUM

PUBLIC DISCOVERY

December 2020 following FireEye/Mandiant investigation

Do not read “18,000” as “18,000 confirmed compromises.” SolarWinds disclosed that fewer than 18,000 customers may have installed affected Orion builds. It later estimated that fewer than 100 customers were actually accessed by the threat actor through SUNBURST. The operation used broad distribution as a funnel and selective exploitation as the operational model.

Strategic significance

Orion was a privileged network-management platform deployed inside high-value environments. A malicious component delivered through a legitimate, digitally signed update inherited the trust already granted to SolarWinds software. The compromise therefore bypassed an important psychological and technical control boundary: defenders were not deciding whether to execute unknown code; they were installing an update from a known vendor.

The most important lesson is not that code signing “failed.” The signed artifact came from SolarWinds. The deeper failure was upstream: the build process that produced the artifact had been manipulated before signing. Authenticity and integrity were therefore evaluated at the wrong layer.

Core model: compromise the builder → manipulate the artifact → sign it legitimately → distribute through trusted channels → profile all exposed environments → promote only selected victims → move from malware-centric access to credential- and identity-centric access.

2. What is known — and what remains uncertain

The public record is unusually rich, but it is not complete. SolarWinds, Mandiant/FireEye, CISA, Microsoft, U.S. government agencies and other researchers documented different layers of the campaign. A rigorous reconstruction must keep vendor estimates, government attribution, incident-response observations and analytical inference separate.

Statement type	How it is treated in this report
Confirmed	Directly supported by primary disclosure, first-party technical analysis or official advisory.
Estimated	Scope or count published by an authoritative party but not necessarily independently verified for every victim.
Attributed	Actor attribution published by a government or established threat-intelligence organization.
Analytical lesson	Defensive or offensive-security conclusion derived from the documented tradecraft.

The unresolved initial entry

Public reporting establishes that the attacker gained access to SolarWinds infrastructure before the malicious Orion updates were produced. The exact initial path into SolarWinds has been discussed through several hypotheses, but the public evidence does not support presenting one unverified path as settled fact. The security lesson is stronger when stated without overclaiming: once the actor obtained sufficient access to the build environment, they could manipulate the output of a trusted software factory.

Why Orion was a high-value target

PRIVILEGE

Network-management software commonly requires broad visibility and trusted access across infrastructure.

POSITION

Orion sat inside enterprise and government networks, often near identity, server and monitoring systems.

DISTRIBUTION

Vendor updates offered a scalable route into many environments without repeating initial access.

TRUST

Signed vendor binaries and expected network behavior reduced suspicion at installation time.

Red-team interpretation: supply-chain attack paths are trust-path attacks. The decisive question is not simply “what binary executed?” but “which upstream relationship caused defenders to allow that binary to execute with privilege?”

3. Reconstructed campaign chronology

2019

Access to SolarWinds environment. The actor establishes a foothold sufficient to study and later manipulate the Orion build process.

Late 2019

Test activity. Public reporting and SolarWinds investigation describe earlier build manipulation/testing before the main SUNBURST distribution period.

February 2020

SUNSPOT build implant active. The implant is associated with monitoring the build process and replacing a legitimate source file at the correct moment so malicious code becomes part of the compiled Orion component.

March–June 2020

Trojanized Orion updates distributed. Affected builds containing SUNBURST are signed and delivered through legitimate SolarWinds update infrastructure.

2020

Selective victim promotion. SUNBURST performs environment checks, delays execution, beacons through DNS and receives instructions. A small subset of attractive victims is promoted to operational C2 and follow-on access.

December 2020

Discovery and public disclosure. FireEye/Mandiant identifies suspicious activity while investigating its own compromise, leading to the SolarWinds connection and rapid government/vendor response.

13–14 December 2020

Emergency response. CISA directs U.S. federal civilian agencies to disconnect affected Orion products; SolarWinds files its 8-K disclosure.

January–April 2021

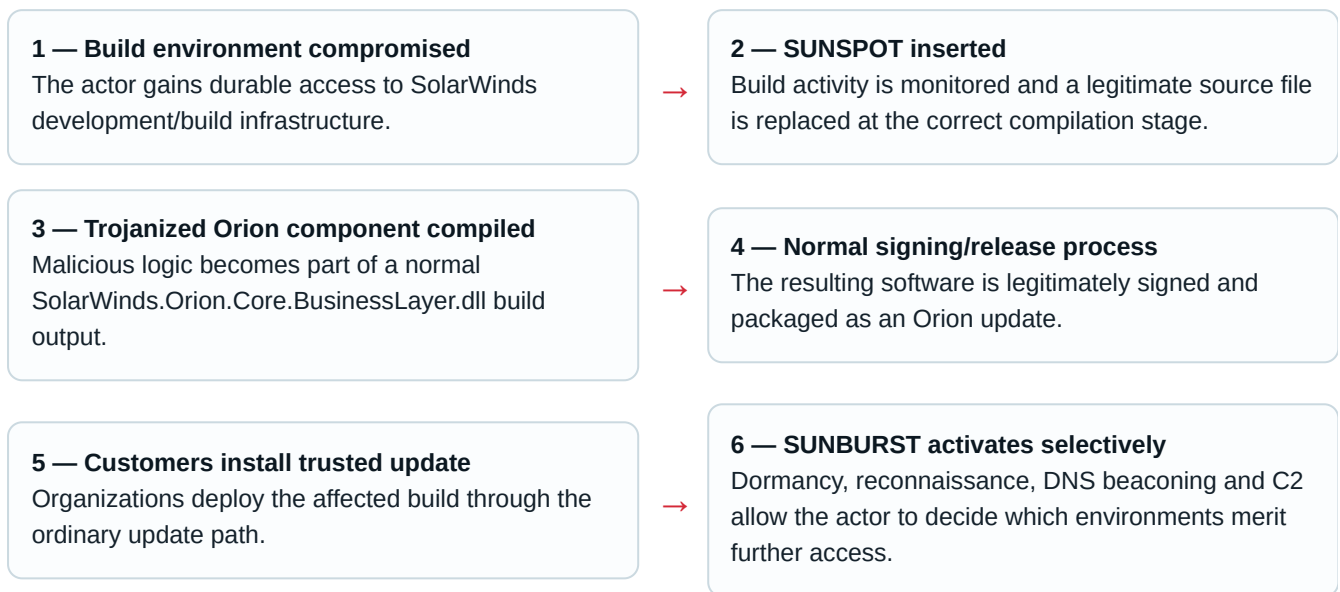
Technical reconstruction and attribution mature. Detailed analysis of SUNSPOT, SUNBURST, identity/cloud tradecraft and post-exploitation is published. U.S. authorities attribute the operation to the Russian SVR.

Campaign design: patience over speed

The operation rewarded stealth. SUNBURST used a deliberate delay before initiating network activity, performed checks to avoid unwanted execution conditions, and relied on staged victim selection rather than immediately deploying noisy tooling everywhere. This created a separation between mass delivery and targeted exploitation.

Operational insight: broad exposure can coexist with narrow hands-on-keyboard activity. Counting infected artifacts alone therefore overstates confirmed compromise while simultaneously understating the seriousness of the selected intrusions.

4. From build compromise to downstream foothold



Why the build layer matters

SolarWinds reported that its investigation found malicious code introduced during the automated build process rather than committed directly to the source-code repository. That distinction matters. Repository review, branch protection and source integrity can all be correct while the final artifact is wrong if the builder is compromised after source review but before signing.

Control	What it proves	What it does not prove
Source review	Reviewed repository content appears legitimate.	The build worker used only that content and was not tampered with.
Code signing	The artifact was signed by the expected signing identity.	The artifact was produced by a trustworthy build path.
Hash verification	The downloaded artifact matches the published hash.	The published artifact itself is benign.
Vendor update channel	The update arrived through an expected distribution mechanism.	The upstream producer was uncompromised.

Defensive requirement: treat `source` → `builder` → `dependencies` → `signing` → `release` → `distribution` as one continuous integrity chain. Attestation must cover the path, not just the endpoint artifact.

5. SUNSPOT — manipulating the software factory

SUNSPOT is the component associated with the SolarWinds build-environment manipulation. Its role was fundamentally different from the downstream SUNBURST backdoor: SUNSPOT existed to influence what SolarWinds built; SUNBURST existed to provide covert access once customers installed the altered update.

Behavioral model

1. **Persist inside the build environment.** The implant runs with access sufficient to observe build orchestration.
2. **Monitor for the target build process.** It waits for the expected compilation conditions rather than modifying every build indiscriminately.
3. **Replace the targeted source file at the correct moment.** A malicious variant is introduced for compilation.
4. **Preserve build reliability.** Operational errors that break production would increase the chance of discovery, so the attacker's design prioritizes normal-looking output and build continuity.
5. **Allow the legitimate pipeline to do the rest.** Compilation, signing, packaging and release transform the attacker's modification into trusted vendor software.

Why SUNSPOT is the strategic center of gravity: once the attacker could reliably influence the builder, every downstream control that trusted the vendor's release process became part of the attacker's delivery infrastructure.

SUNSPOT vs. SUNBURST

	SUNSPOT	SUNBURST
Location	SolarWinds build environment	Downstream customer systems running affected Orion builds
Purpose	Inject malicious code into the build output	Establish covert victim-side access and selection
Audience	The software factory	Potential downstream victims
Operational value	Scalable trusted distribution	Reconnaissance, C2 and access brokerage

6. SUNBURST — stealth, profiling and victim selection

SUNBURST was embedded in a legitimate Orion component and inherited the execution context of trusted SolarWinds software. Its behavior was designed to reduce immediate detection, learn enough about the environment to support selection, and communicate through infrastructure that blended into ordinary enterprise traffic.

Key technical characteristics

DORMANCY

A substantial delay before network activity reduced the correlation between update installation and malicious behavior.

ENVIRONMENT CHECKS

The malware examined host and process conditions and attempted to avoid environments likely to expose or disrupt the operation.

DNS-CENTRIC FIRST STAGE

Victim information was encoded into DNS lookups under attacker-controlled infrastructure, creating a low-volume discovery and selection channel.

STAGED C2

Selected victims could be directed toward additional command-and-control infrastructure instead of treating every infected environment equally.

LEGITIMATE HOST PROCESS

Execution within the Orion software context made process-based trust assumptions less useful.

OPERATIONAL RESTRAINT

The actor minimized noisy actions until an environment had been evaluated for value.

Detection lesson: “signed,” “vendor-owned,” and “expected process name” are context, not verdicts. Behavioral analytics must still evaluate outbound communication, parent/child relationships, unusual DNS patterns, credential use and identity events.

The selection funnel

Stage	Population	Attacker decision
Affected build	Potentially thousands of installations	Observe environment while maintaining low visibility.
DNS beaconing	Hosts that activate and communicate	Identify organizational/network characteristics.
Promoted victim	Small, high-value subset	Move to operational C2 and follow-on access.
Hands-on intrusion	Selected targets	Acquire credentials, expand access, collect and persist.

7. Beyond SUNBURST: moving from malware to identity

SUNBURST should not be understood as the entire intrusion set. In promoted environments the actor could deploy additional tooling and, more importantly, transition toward valid credentials, remote access, cloud identities and living-off-the-land techniques. Once that transition occurred, the original Orion foothold was no longer the only persistence or access problem.

Follow-on tooling

Public reporting associated the campaign with follow-on loaders including **TEARDROP** and **RAINDROP**, as well as Cobalt Strike components in some environments. Tooling varied by victim, which is precisely why a response strategy based only on one malware family or one hash was insufficient.

Operational patterns that matter to defenders

- Credential acquisition and use of legitimate accounts.
- Remote services and administrative mechanisms that resemble normal operator behavior.
- Lateral movement toward identity, email, management and other high-value systems.
- Cloud access that can persist independently from the original on-premises Orion server.
- Creation or abuse of service principals, applications, tokens or federation relationships where the victim architecture permits it.
- Careful use of infrastructure and operational timing intended to reduce correlation across victims.

Incident-response consequence: deleting SUNBURST or patching Orion is not equivalent to eviction. If follow-on access produced valid credentials, federation-signing capability, service-principal permissions or other durable identity paths, remediation must coordinate endpoint, Active Directory and cloud actions.

Identity as the long-term objective

Management software can provide a privileged beachhead, but identity systems provide reach. A sophisticated actor benefits from trading malware-based access for access that uses credentials and tokens accepted by the victim's own security model. This reduces dependence on the original implant and complicates forensic scoping.

8. Active Directory, federation and M365 implications

The SolarWinds response highlighted a recurring problem in hybrid enterprise incidents: compromise can cross the boundary between on-premises administrative systems and cloud identity. Defenders therefore need to understand not just where code ran, but which identities, credentials and trust anchors were reachable from the compromised environment.

Area	Risk to investigate	Response priority
Privileged AD accounts	Stolen credentials, abnormal authentication, lateral movement	Reset/rotate in a controlled sequence after scoping persistence
Federation / token signing	Ability to mint or abuse trusted authentication tokens	Rotate signing material and validate federation configuration
Cloud applications	Unexpected credentials, consent grants, service-principal permissions	Inventory, revoke and re-establish trusted application state
Mail / collaboration	Mailbox access, collection, forwarding or application-based access	Review audit logs and high-value accounts over the full retention window
Remote access	Legitimate VPN/RDP/admin use by the actor	Correlate identity, network and endpoint telemetry

Why coordinated eviction matters

Resetting one credential too early can alert the actor while leaving another persistence path intact. Mature incident response therefore plans an eviction window: understand access paths, prepare clean administrative identities, rotate credentials and trust material, remove persistence, block known infrastructure, rebuild where necessary and monitor for re-entry.

Architecture lesson: tier administrative identities and prevent monitoring/build/management infrastructure from becoming an easy stepping stone into the organization's identity control plane.

9. Hunting and detection opportunities

Static indicators played an important role in emergency response, but the enduring value of the case lies in behavior and telemetry. Historical domains and hashes age quickly; the underlying attack logic remains relevant.

Telemetry priorities

Telemetry	What to hunt for
DNS	Historical queries associated with Orion hosts, unusual encoded subdomains, low-frequency beaconing and resolver records retained across the exposure period.
Proxy / firewall	Unexpected outbound communication from management servers, especially destinations or patterns inconsistent with normal vendor behavior.
EDR / process	Unusual child processes, memory activity or follow-on execution from trusted management-service contexts.
Identity	Privileged account use from unusual hosts, token anomalies, new credentials, service-principal changes, anomalous remote logons.
Cloud audit	Application consent, role changes, mailbox access and token use that cannot be explained by normal administration.
Build / CI	Unexpected worker modifications, source/output mismatch, anomalous process injection, signing requests not traceable to approved provenance.

Detection design principles

- **Baseline privileged infrastructure separately.** Management servers deserve stricter egress expectations than ordinary endpoints.
- **Retain enough history.** Supply-chain campaigns can be discovered months after initial exposure.
- **Correlate across layers.** DNS alone may be ambiguous; DNS + Orion host + identity anomalies is much stronger.
- **Do not exempt trusted software from behavior analytics.** Signed binaries can still become execution containers for malicious behavior.
- **Preserve forensic evidence before destructive remediation.** Rebuilding too early can erase the trail needed to determine whether the actor moved beyond Orion.

High-value detection question: what outbound destinations, child processes and identity actions are acceptable for each privileged management platform? “It is a trusted server” should produce a narrower baseline, not a wider exemption.

10. Exposure, compromise and coordinated remediation

Understanding the impact funnel

The public narrative often collapses four different states into one number: customer of SolarWinds, installer of an affected build, host that communicated through SUNBURST, and organization selected for follow-on compromise. Those states are operationally different and should be reported separately.

State	Meaning	Response implication
Affected product/customer	Potential exposure based on version/build	Identify installations and preserve logs
SUNBURST execution	Malicious component ran	Treat host and surrounding trust relationships as suspect
Actor-selected victim	Evidence of operational C2 / follow-on access	Escalate to full incident response and identity/cloud scoping
Confirmed post-exploitation	Hands-on activity, credentials or persistence beyond Orion	Coordinated eviction, rebuild and long-term monitoring

Recommended response sequence

1. Identify affected Orion versions and isolate or remove them according to authoritative guidance.
2. Preserve endpoint, DNS, proxy, identity, cloud and remote-access logs for the entire possible exposure window.
3. Hunt for evidence that the actor moved from the Orion process into additional tooling or valid-account activity.
4. Scope privileged identities, federation, application credentials and cloud permissions.
5. Prepare clean administrative infrastructure and an eviction plan before rotating critical secrets.
6. Rebuild compromised high-trust systems rather than assuming malware deletion restores trust.
7. Increase monitoring after eviction for re-entry through credentials or persistence missed during scoping.

Key distinction: containment stops current activity; eradication removes known artifacts; eviction removes the actor's viable access paths. SolarWinds-class incidents require all three.

11. Representative technique mapping

This mapping is representative rather than exhaustive. Follow-on tradecraft differed by victim and evolved after the initial SUNBURST access.

Tactic / theme	Representative technique	SolarWinds relevance
Initial Access	T1195 — Supply Chain Compromise	Compromised software build/update path delivered malicious code through trusted vendor distribution.
Execution	T1059 — Command and Scripting Interpreter	Follow-on operations used native scripting/command mechanisms where appropriate.
Persistence / Defense Evasion	T1078 — Valid Accounts	Stolen or abused identities can outlive the original malware foothold.
Discovery	T1082 / T1016	System and network characteristics contributed to environmental awareness and victim selection.
Command & Control	T1071.004 — DNS	DNS was central to initial SUNBURST beaconing and selection logic.
Command & Control	T1071.001 — Web Protocols	HTTP(S)-based communications blended with expected enterprise traffic.
Lateral Movement	T1021 — Remote Services	Selected intrusions could use legitimate remote administration paths.
Credential Access	T1555 / related credential theft	Credential acquisition supported durable, legitimate-looking access.
Collection	T1114 — Email Collection	High-value cloud/email access was relevant in government/enterprise espionage objectives.
Defense Evasion	T1036 — Masquerading	Trusted vendor context and legitimate infrastructure complicated detection.

T1195 Supply Chain

T1078 Valid Accounts

T1071.004 DNS

T1021 Remote Services

T1114 Email Collection

ATT&CK is a map, not the incident

Technique IDs help normalize behavior across tooling, but they should not replace sequence and trust analysis. The defining characteristic of SolarWinds was not any individual post-exploitation technique; it was the actor's ability to enter through a signed, trusted supply-chain artifact and then selectively convert that access into conventional espionage tradecraft.

12. Controls that raise the cost of a SolarWinds-class operation

Layer	Priority controls
CI/CD identity	Short-lived workload identity, least privilege, MFA for human administration, no shared long-lived credentials, strict separation between source/build/signing roles.
Build isolation	Ephemeral workers, hardened golden images, minimal network access, immutable infrastructure, independent monitoring of the build control plane.
Provenance	Signed build attestations, traceability from reviewed source to artifact, reproducible or independently verified builds where practical.
Signing	Hardware-backed or isolated signing services, policy-bound signing requests, separation from general build hosts, audit logs for every signature.
Release	Immutable artifacts, signed manifests, independent verification before promotion, controlled update publishing.
Enterprise egress	Deny-by-default or tightly baselined outbound access from privileged management servers; DNS/proxy logging with long retention.
Identity	Admin tiering, service-principal governance, token/federation monitoring, separation of management platforms from identity control-plane privilege.
Response readiness	Preplanned coordinated eviction, clean admin paths, credential rotation playbooks, preserved telemetry across endpoint/network/cloud.

What changed after SolarWinds

The incident accelerated industry attention toward software provenance, secure build systems, SBOMs, artifact attestation and formal software-supply-chain frameworks. Those controls are useful only when they reflect actual trust boundaries. An SBOM can describe components while a compromised builder still changes the artifact; a signature can authenticate a release while a compromised signing path legitimizes malicious output.

Design principle: no single control should be able to assert “this release is trusted” without independent evidence from adjacent stages. High-assurance pipelines need separation of duties plus verifiable provenance.

13. What this case teaches offensive and defensive practitioners

For Red Teams

- **Model trust paths, not only host vulnerabilities.** CI/CD, package registries, deployment systems, management platforms and identity bridges can have a blast radius far larger than an individual endpoint.
- **Test detection on trusted processes.** Defenders may over-allow vendor agents. Emulations should evaluate whether behavioral controls still trigger when activity originates from an approved management process.
- **Measure the privilege of software factories.** Build workers and signing systems often combine code execution, secrets and distribution capability.
- **Emulate victim selection and restraint.** A realistic advanced operation does not need to detonate every capability everywhere. Selective promotion is a useful way to test whether defenders can correlate weak signals.
- **Include identity/cloud follow-through.** The meaningful question is whether initial access can be converted into durable access through the organization's trust fabric.

For Detection / IR Teams

- Maintain historical telemetry long enough to reconstruct delayed-discovery campaigns.
- Define expected egress for privileged management servers and CI systems.
- Build response plans that rotate identity and trust material in a coordinated eviction window.
- Track artifact provenance independently from code signing.
- Assume that a trusted vendor process can become an adversary-controlled execution context.

Study questions

1. If an attacker compromises your build worker but never commits malicious source, which controls detect the change?
2. Can your signing service prove what source and dependencies produced the artifact it is asked to sign?
3. How long can you retrospectively query DNS, identity and cloud audit logs?
4. Which management platforms can reach your identity control plane, and with what privilege?
5. Could you rotate federation/token-signing material without losing administrative access during an incident?

Research takeaway: SolarWinds is a study in asymmetry. A carefully positioned compromise upstream allowed one actor to inherit the reach, reputation and distribution machinery of a legitimate software vendor.

14. Attack-path reconstruction through trust boundaries

The most useful way to model SolarWinds is not as a linear malware chain, but as a sequence of **trust-boundary conversions**. At each transition, access obtained in one control plane was converted into authority in the next. The malware mattered, but the strategic advantage came from inheriting trust that already existed.

Trust boundary	Attacker leverage	Defender assumption placed at risk
Build control plane	Manipulate what the software factory emits without requiring a visible malicious source-code commit.	Reviewed source and a controlled repository are sufficient evidence that the release artifact is trustworthy.
Signing / release plane	Allow the modified artifact to move through legitimate signing and vendor distribution.	A valid vendor signature implies the upstream build path was uncompromised.
Customer management plane	Execute inside an already trusted network-management product with privileged visibility and expected connectivity.	Approved infrastructure software deserves broader behavioral exemptions than ordinary processes.
Enterprise identity plane	Convert malware-mediated access into valid-account, token, service-principal or federation-based access.	Removing the original implant restores the security boundary.
Cloud / data plane	Use identity-derived access to reach email, applications and sensitive information with fewer malware-specific signals.	Endpoint remediation and IOC blocking are sufficient to end the intrusion.

Where the attack changes character

The decisive transition is the move from **artifact-centric access** to **identity-centric access**. Before that point, the defender can still reason primarily about a compromised product, process and network path. After that point, the intrusion can survive as apparently legitimate authentication and administrative activity even if the original Orion component is removed.

Analytical model: build compromise → trusted artifact → privileged execution context → selective victim promotion → identity conversion → durable enterprise/cloud access. The closer the actor moves toward identity, the less useful a malware-only response becomes.

Highest-value defensive choke points

- **Before signing:** independently verify provenance between reviewed source, dependencies, build worker and produced artifact.
- **Before deployment:** treat privileged management software as a constrained execution environment, not a blanket trust exception.
- **Before identity conversion:** isolate management systems from federation, tier-zero administration and unrestricted credential material.

- **After suspected promotion:** scope identity and cloud activity immediately instead of waiting for a second malware family to appear.

Michel-DV analysis: the operational center of gravity was not SUNBURST itself. It was the sequence of trust relationships that allowed SUNBURST to become progressively less necessary after access was converted into legitimate-looking identity and administrative paths.

15. Detection hypotheses: where the campaign could surface

These are **detection hypotheses**, not claims that any single rule would have reliably detected the historical operation. Their purpose is to convert the reconstructed attack path into testable telemetry questions that remain useful against future supply-chain intrusions.

Phase	Detection hypothesis	Primary telemetry
Build manipulation	A release artifact differs from what independently rebuilt or provenance-verified inputs should produce, despite no corresponding reviewed source change.	CI worker audit, artifact hashes, reproducible-build comparison, build attestations, signing request logs
Trusted execution	A privileged management service begins network or process behavior outside its historically narrow operating profile.	EDR, parent/child process telemetry, proxy/firewall, application baselines
Victim selection	Low-frequency or structured DNS activity from management hosts correlates with previously unseen external infrastructure.	Long-retention DNS, resolver telemetry, passive DNS, asset role context
Promotion / follow-on	A trusted server becomes the origin of scripting, remote administration or credential use that is unusual for that system's normal role.	EDR, PowerShell/script logging, remote-service logs, authentication telemetry
Identity conversion	Privileged credentials, application identities or token-related operations appear from hosts and sequences that do not match normal administrative workflows.	AD authentication, federation logs, IdP audit, service-principal changes, privileged-access telemetry
Cloud persistence / collection	New application access, mailbox activity or cloud role changes occur shortly after suspicious activity on a high-trust on-premises management system.	M365 / cloud audit, mailbox logs, OAuth consent, role and application audit trails

Signal quality improves through correlation

Most individual signals above are weak in isolation. The stronger model is **cross-layer correlation**: a high-trust management host produces unusual DNS, then launches atypical child activity, followed by privileged authentication or cloud changes. Each event may be explainable alone; the ordered sequence is materially harder to dismiss.

Historical-data requirement: delayed discovery changes the economics of detection. If DNS, identity and cloud audit data expire after a few days, defenders can lose the ability to distinguish broad exposure from selected follow-on compromise when the incident is finally understood.

Detection engineering test

A useful purple-team exercise is to ask whether a trusted management server can generate each class of signal without being automatically suppressed because of its vendor, signature, service account or asset role. High trust should create a **narrower behavioral envelope**, not a larger blind spot.

16. Red Team research notes: what to emulate safely

The useful Red Team lesson is not to reproduce a real third-party supply-chain compromise. It is to emulate the **trust assumptions** the operation exploited, inside an explicitly authorized environment, and measure whether defensive controls still work when activity originates from systems defenders already trust.

Research objective	Safe emulation pattern	Success criterion
Trusted-process blind spot	Run benign test actions from an approved lab management-service context or controlled surrogate process.	Behavioral controls alert on anomalous activity despite trusted path, signature or asset reputation.
Build integrity	Introduce a controlled difference between reviewed input and lab build output without touching production distribution.	Independent provenance or reproducibility checks identify the mismatch before release promotion.
Signing governance	Submit a deliberately non-compliant artifact to a test signing path using authorized credentials.	Policy blocks signing because provenance, requester, build identity or approval chain is incomplete.
Selective promotion	Generate low-noise beacons from multiple lab assets, then activate follow-on simulation only on a designated target.	Defenders correlate the weak precursor with later activity instead of treating each signal independently.
Identity follow-through	Use pre-created test identities/tokens to simulate movement from a compromised management tier toward a lab identity or cloud control plane.	Tiering, conditional access and identity telemetry detect or prevent the trust transition.

What should not be part of the emulation

- Compromising or modifying a real vendor, public package, update channel or third-party dependency.
- Publishing poisoned artifacts outside the authorized laboratory or engagement boundary.
- Using real production signing keys or federation material when equivalent test credentials can validate the control.
- Leaving persistent access, altered trust relationships or live credentials behind after the exercise.

Research value

This framing separates **capability imitation** from **security-control validation**. A Red Team does not need nation-state access to a software vendor to test the same defensive assumptions: whether trusted infrastructure is over-privileged, whether artifact provenance is independently verified, whether egress from management systems is constrained, and whether identity boundaries stop an initial foothold from becoming durable access.

Final Red Team takeaway: emulate the trust transition, not the geopolitical scale. The strongest exercise is the smallest authorized action that proves whether the same defensive assumption can still be abused.

17. Common myths, indicators and terminology

Common myths

Myth	Correction
"18,000 organizations were hacked."	Fewer than 18,000 customers may have installed affected builds; that is not the same as confirmed follow-on compromise.
"Code signing was bypassed."	The malicious build was signed legitimately. The upstream build process had been manipulated.
"SUNSPOT and SUNBURST are the same malware."	SUNSPOT targeted the build process; SUNBURST was delivered to customers.
"Removing Orion removes the actor."	Not if follow-on access established credentials, cloud permissions, tokens or other persistence.
"SUPERNOVA was another SUNBURST stage."	CISA assessed SUPERNOVA as a separate malware campaign associated with a different actor.

Representative historical indicators

For retrospective research only. Historical indicators should not be treated as current threat intelligence without contemporary validation.

```
SolarWinds.Orion.Core.BusinessLayer.dll  
avsvmcloud[.]com  
SUNBURST / Solorigate  
SUNSPOT  
TEARDROP / RAINDROP
```

Glossary

Build pipeline	Automated system that transforms source and dependencies into release artifacts.
Supply-chain compromise	Attack on a supplier, dependency or delivery mechanism used to reach downstream targets.
Provenance	Evidence describing where, how and from what inputs an artifact was produced.
Victim promotion	Selection of an exposed environment for deeper hands-on exploitation.
Coordinated eviction	Synchronized removal of malware, credentials, persistence and trust abuse to prevent easy re-entry.

18. Evidence trail

This case study prioritizes primary disclosures, official advisories and first-party technical analysis. The repository also maintains a browsable reference index at `docs/REFERENCES.md`.

1. SolarWinds, Form 8-K, 14 Dec 2020 — <https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm>
2. SolarWinds, investigative update / SEC filing, 2021 — <https://www.sec.gov/Archives/edgar/data/1739942/000173994221000080/swi-20210331.htm>
3. Mandiant / FireEye, "Highly Evasive Attacker Leverages SolarWinds Supply Chain..." — <https://cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor/>
4. Mandiant, "SUNBURST Additional Technical Details" — <https://cloud.google.com/blog/topics/threat-intelligence/sunburst-additional-technical-details/>
5. CISA, "Active Exploitation of SolarWinds Software" — <https://www.cisa.gov/news-events/alerts/2020/12/13/active-exploitation-solarwinds-software>
6. CISA / NSA / FBI, AA21-116A — <https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-116a>
7. U.S. GAO, GAO-22-104746 — <https://www.gao.gov/products/gao-22-104746>
8. CISA, "Supply Chain Compromise: Detecting APT Activity from Known TTPs" — https://www.cisa.gov/sites/default/files/publications/Supply_Chain_Compromise_Detecting_APT_Activity_from_known_TTPs.pdf
9. CISA, SUPERNOVA Malware During Incident Response — <https://www.cisa.gov/news-events/analysis-reports/ar21-112a>
10. Mandiant, UNC2452 merged into APT29 — <https://cloud.google.com/blog/topics/threat-intelligence/unc2452-merged-into-apt29/>
11. CISA, eviction guidance — <https://www.cisa.gov/news-events/news/cisa-releases-eviction-guidance-help-organizations-remove-russian-state-sponsored-threats>
12. SolarWinds, investigation update, 11 Jan 2021 — <https://www.sec.gov/Archives/edgar/data/1739942/000173994221000015/swi-20210111.htm>

Attribution note: the United States publicly attributed the campaign to the Russian Foreign Intelligence Service (SVR). Threat-intelligence naming varies across vendors; APT29 and NOBELIUM are commonly associated with the actor set relevant to this campaign.

Publication metadata

Author: Michel-DV / @Michel-DV

Repository: github.com/Michel-DV/solarwinds-supply-chain-case-study

Version: 1.1.0

Published: 15 September 2026

License: CC BY-NC-ND 4.0

Independent research publication. Not affiliated with or endorsed by SolarWinds, Mandiant, CISA, Microsoft, MITRE or other referenced organizations. Product names and trademarks remain the property of their respective owners.